

Chapter 7

Administering security

- Administering security requires moving from individual configurations to a strategic framework.

Security planning

Security planning provides the roadmap for this by identifying what needs protection, defining how to protect it, and detailing what to do if those defenses fail.

Core Components of a Security Plan

- A comprehensive System Security Plan (SSP) typically includes these essential sections:
 - **System Identification:** Clearly defining the system boundaries, physical locations, and technical environment (hardware, software, network).
 - **Roles & Responsibilities:** Designating who is accountable for specific security tasks, such as the CISO, network admins, and data owners.
 - **Security Controls:** Detailing the technical (firewalls, MFA), administrative (policies, training), and physical (locks, cameras) measures in place.
 - **Risk Assessment:** Periodically identifying vulnerabilities and prioritizing threats based on their potential impact on the business.

The Planning Process (Step-by-Step)

- Security planning is a cyclical process, often aligned with frameworks like **NIST CSF 2.0**:
- **Inventory & Scope**: Identify all assets (devices, data, users) that need protection.
- **Assess Posture**: Evaluate current security measures against a desired target state.
- **Define Policies**: Create clear rules for organizational behavior, such as **Acceptable Use Policies (AUP)** and **Access Control Policies**.
- **Implement Controls**: Deploy technical barriers like firewalls, encryption, and Multi-Factor Authentication (MFA).

- **Train Staff:** Educate employees to recognize threats like phishing, as human error is a major vulnerability.
- **Continuous Monitoring:** Use tools like SIEM or IDS/IPS to detect anomalies in real-time.
- **Resilience & Recovery**
- Planning must assume that a breach will eventually occur. This involves two distinct but related plans:
 - **Business Continuity Plan (BCP):** A broad, proactive plan to keep critical business operations running *during* a disruption (e.g., switching to manual processes or remote work).
 - **Disaster Recovery Plan (DRP):** A technical, reactive subset of the BCP focused specifically on restoring IT systems and data *after* a failure

risk analysis

- In computer security, **risk analysis** is the systematic process of identifying potential threats, evaluating the likelihood of those threats occurring, and assessing their potential impact on organizational assets.
- It provides the data-driven foundation needed to prioritize security investments and choose effective countermeasures.

1. Two Main Methodologies

- Organizations typically use a combination of these two approaches to gain a full view of their risk posture:

A. Qualitative Risk Analysis: A subjective, scenario-based approach that ranks risks (e.g., Low, Medium, High) based on expert judgment and descriptive information.

- It is fast, easy to communicate to non-technical stakeholders, and ideal for initial screenings.

B. Quantitative Risk Analysis: An objective, data-driven method that assigns numeric and monetary values to risk factors.

- It calculates precise metrics like **Annual Loss Expectancy (ALE)** to provide a clear financial justification for security spending.

2. The Risk Analysis Process

- A standard risk analysis follows these critical steps:
 - **Asset Identification:** Cataloging hardware, software, data, and personnel to understand what needs protection.
 - **Threat & Vulnerability Assessment:** Identifying potential threats (e.g., hackers, malware, natural disasters) and the weaknesses
 - (e.g., unpatched software, weak passwords) they could exploit.
 - **Likelihood and Impact Assessment:** Determining the probability of an event and the severity of its consequences
 - such as financial loss, reputational damage, or operational downtime.
 - **Risk Prioritization:** Using a **risk matrix** to rank findings and focus resources on the most critical exposures.

3. Risk Treatment Options

- Once risks are analyzed, administrators must choose how to respond to each:
- **Mitigate (Reduce):** Implementing security controls
 - (e.g., firewalls, MFA) to lower the risk to an acceptable level.
- **Transfer (Assign):** Shifting the financial burden to a third party, often through cyber insurance or outsourcing.
- **Avoid:** Eliminating the risk entirely by ceasing the risky activity or removing the vulnerable technology.
- **Accept:** Acknowledging the risk exists and choosing not to act, usually because the cost of mitigation outweighs the potential loss

Security Policies

- In the world of computer security, **Security Policies** are high-level documents that outline the "rules of the road" for an organization. They define what is expected from employees and how the technology should be protected.
- **1. The Three Main Types of Policies**
- Professional security administration usually breaks policies into three categories:
- **Program Policy:** A high-level document signed by the CEO or Board. it sets the overall security goals and tone for the entire company.
- **Issue-Specific Policy (ISSP):** Focuses on a single area of concern.
 - *Examples:* **Email Policy**, **Social Media Policy**, or **Remote Work Policy**.
- **System-Specific Policy (SysSP):** Technical guidelines for specific hardware or software.
 - *Example:* A policy detailing how a **Web Application Firewall (WAF)** or a **RADIUS server** must be configured.

2. Common Security Policies You'll Encounter

- **Acceptable Use Policy (AUP):** The most common policy. It tells employees what they can and cannot do on company computers (e.g., "No illegal downloads," "No visiting gambling sites").
- **Access Control Policy:** Defines who gets access to what data and which model (DAC, MAC, or RBAC) will be used to enforce it.
- **Password/Credential Policy:** Sets requirements for password length, rotation, and the mandatory use of Multi-Factor Authentication (MFA).
- **Data Retention Policy:** Dictates how long data must be kept and how it should be destroyed (e.g., "Delete all customer emails after 7 years").

3. What Makes a Policy "Good"?

- For a policy to be effective and legally binding, it must be:
 - **Disseminated:** Everyone must be able to read it.
 - **Understood:** It should be written in plain language, not just "legalese."
 - **Encouraged:** Employees should be trained on it.
 - **Enforced:** There must be clear consequences for breaking the rules, applied fairly to everyone from the intern to the CEO.
- **4. Policy vs. Standard vs. Procedure**
 - Administrators use these three terms to create a complete system:
 - **Policy:** The high-level "Why" and "What" (e.g., "We must use strong passwords").
 - **Standard:** The mandatory "Requirement" (e.g., "Passwords must be 14 characters long").
 - **Procedure:** The step-by-step "How-to" (e.g., "To change your password, press Ctrl+Alt+Del and click...").

Cybersecurity

- In the context of administering security, **cyber security** refers to the day-to-day management of digital defenses to protect an organization's network, devices, and data.

Core Pillars of Modern Administration (2024–2025)

- Effective cybersecurity administration now centers on five key pillars designed to handle increasingly sophisticated, AI-driven threats:

- **Zero Trust Architecture (ZTA):** The default model where no user or device is trusted by default, regardless of their location. It requires continuous verification of user identity and device health for every access request.
- **Identity-First Strategy:** Identity is now viewed as the new security perimeter. Administrators are moving away from simple passwords toward **Passkeys** and **Biometric Encryption** to stop the surge in credential-based attacks.

- **AI-Driven Defense:** Security teams use AI and Machine Learning (ML) to analyze vast amounts of data in real time, detecting subtle anomalies that traditional tools might miss.
- **Cyber Resilience:** Shifting from just "preventing" attacks to ensuring the business can **continue operating** during a breach and recover quickly afterward.
- **Supply Chain & Third-Party Risk:** Managing the security of vendors and software updates has become a top priority following high-profile disruptions like the CrowdStrike incident.

Key Administrative Challenges

- **Shadow AI:** The unsanctioned use of AI tools by employees, which can lead to data leaks if not properly governed.
- **Sophisticated Phishing:** AI-powered social engineering, including **deep fake audio and video**, is making it harder for staff to detect fraudulent requests.
- **Post-Quantum Preparation:** Administrators are beginning to inventory their encrypted assets to prepare for future quantum computing threats that could break current encryption standards.

Top 3 Actionable Best Practices

- **Enforce Multi-Factor Authentication (MFA):** Prioritize physical security keys (like FIDO2 keys) over SMS codes to prevent token hijacking.
- **Continuous Patch Management:** Automate software updates to close vulnerabilities before they can be exploited by automated AI scanning tools.
- **Human-Centric Training:** Move beyond generic lectures toward **role-specific, simulation-based training** that reflects current threats like "smishing" (SMS phishing) and QR code scams.

Ethics

- In the realm of security administration, **Ethics** refers to the moral principles that govern how a security professional handles sensitive data, monitors users, and wields their "God-mode" powers.
- Because administrators often have the keys to the kingdom, technical skill must be balanced with high integrity.

1. The Power vs. Privacy Dilemma

- As a security administrator, you technically *can* read anyone's email or see their private files. Ethics defines the line between **security monitoring** and **invasion of privacy**.
- **Ethical Standard:** Only access data that is strictly necessary for a specific security investigation or maintenance task.
- **The "Rule of Two":** Many organizations require two admins to be present (or logged) when accessing highly sensitive personal data to ensure accountability.

2. Professional Codes of Ethics

- Most cybersecurity certifications require members to sign a formal code of ethics. The most famous is from **(ISC)²** (for CISSP holders):
- **Protect society and the common good.**
- **Act honorably, honestly, justly, responsibly, and legally.**
- **Provide diligent and competent service.**
- **Advance and protect the profession.**

3. Key Ethical Challenges for Admins

- **Whistleblowing:** What do you do if you find evidence of your company doing something illegal while you are performing a routine audit?
- **Vulnerability Disclosure:** If you find a bug in a software your company uses, do you tell the vendor privately (Ethical), or do you post it online for fame (Unethical)?
- **Privileged Access Abuse:** Using your admin rights to help a friend, bypass your own manager's restrictions, or "snoop" on a coworker.

4. Logic vs. Ethics: The "White Hat" Approach

- Security professionals are often categorized by their ethical alignment:
- **White Hat:** Ethical hackers who use their skills for good, always with permission and legal authorization.
- **Black Hat:** Unethical hackers who break into systems for personal gain or malice.
- **Grey Hat:** Those who might break the law or bypass policies "for a good reason" (like finding a bug without permission) but without malicious intent.

5. Data Handling & Integrity

- Ethics also applies to how you report security status. An ethical admin does not hide a breach to protect their reputation; they report it accurately and immediately to ensure the organization can take action.